Application des notes

Owner: lamyae
Reviewer:
Contributors:
Date Generated: Wed Oct 28 2026

Executive Summary

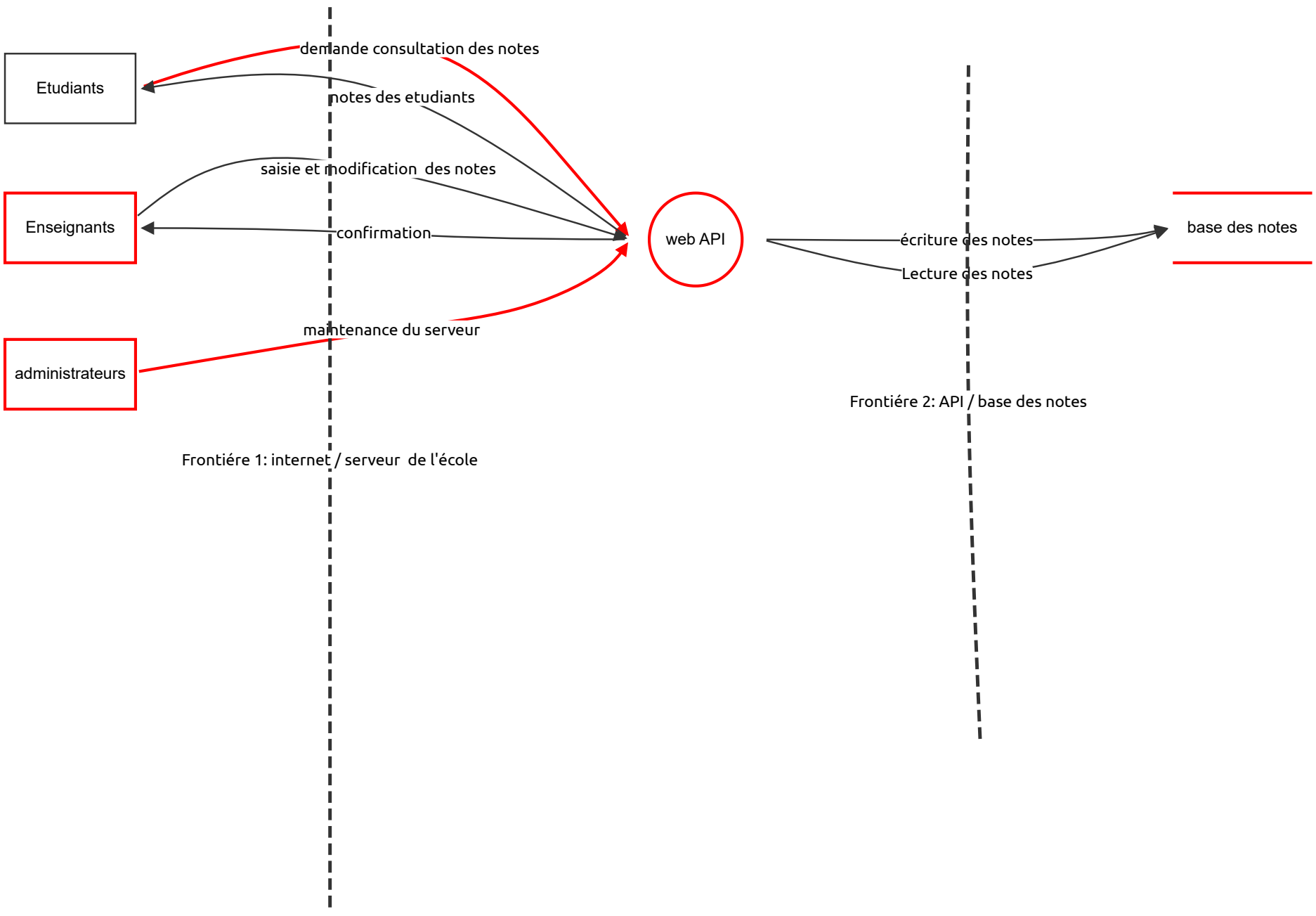
High level system description

API web Flask (Python) permettant aux étudiants de consulter leurs notes depuis leur téléphone, aux enseignants de saisir et modifier les notes, et à l'administrateur de maintenir le serveur. Les notes sont stockées dans une base SQLite sur le serveur.

Summary

Total Threats	12
Total Mitigated	0
Total Open	12
Open / Critical Severity	1
Open / High Severity	6
Open / Medium Severity	3
Open / Low Severity	1
Open / TBD Severity	1

Flux de données



Flux de données

Etudiants (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Enseignants (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Usurpation de l'identité d'un enseignant	Spoofing	High	Open		Un attaquant se fait passer pour un enseignant, par exemple avec un jeton volé ou deviné.	Jetons secrets et à durée limitée, authentification forte.
5	Un enseignant nie avoir modifié une note	Repudiation	Medium	Open		Sans trace fiable, l'enseignant peut contester une modification.	Journalisation (qui, quoi, quand)

administrateurs (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	New STRIDE threat	Spoofing	TBD	Open		Provide a description for this threat	Provide remediation for this threat or a reason if status is N/A

web API (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Injection SQL	Tampering	Critical	Open		La concaténation de request.args["note"] dans la requête SQL permet de modifier ou détruire les données.	Requêtes paramétrées, validation des entrées
7	Usurpation d'identité par jeton volé	Spoofing	High	Open		Un attaquant utilise le jeton d'un enseignant ou d'un étudiant pour se faire passer pour lui.	Jetons secrets, expiration, rotation

base des notes (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Modification directe de la base	Tampering	High	Open		Un accès au serveur permet de modifier notes.db sans passer par l'API.	Permissions du fichier, accès restreint, sauvegardes
9	Lecture non autorisée de la base	Information disclosure	High	Open		Le fichier notes.db est copié ou lu par quelqu'un qui n'y a pas droit	Droits système, chiffrement du disque

saisie et modification des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

demande consultation des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Interception des notes en transit	Information disclosure	High	Open		Sans chiffrement, un attaquant sur le Wi-Fi ou le réseau mobile peut lire les notes et le jeton.	HTTPS/TLS obligatoire, HSTS
2	Modification de la requête en transit	Tampering	Medium	Open		Un attaquant intercepte et modifie la requête ou la réponse (par exemple l'identifiant de l'étudiant).	TLS, validation côté serveur
3	Saturation par des requêtes en masse	Denial of service	Medium	Open		Un grand nombre de requêtes depuis des téléphones rend l'API indisponible pendant la consultation des notes.	Limitation du débit (rate limiting), pare-feu

notes des etudiants (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

confirmation (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

maintenance du serveur (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Interception des identifiants admin	Information disclosure	High	Open		Les commandes et identifiants de maintenance circulent en clair.	Accès par SSH/VPN, TLS
12	Déni de service sur l'accès de maintenance	Denial of service	Low	Open		L'accès d'administration est saturé et la maintenance devient impossible	Restriction par IP, limitation du débit

écriture des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Lecture des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations